

Appendix B Prompt Library

B.1 Purpose and use

This appendix holds the five master prompts used in the study, together with the two input blocks that several of them draw on. It is a working instrument rather than an account of the design.

The prompt conditions, the phase sequence and the assembly of the blocks are set out in Chapter 3, Sections 3.6 and 3.7. Figure 3.2 shows which block enters which prompt.

A prompt is assembled by taking the master prompt text as printed and replacing each marked insertion point with the named block, in the order shown.

No prompt was retyped or amended at the point of use, and none was altered once a run had taken place.

Three document codes appear in the prompts: SB-01R is the Scenario Brief at Appendix A, REQ-01 the requirement extract at Appendix C, and RUB-01 the Policy Evaluation Rubric at Appendix D.

B.2 Shared input blocks

Master Prompts A, B, C and D embed both blocks; Master Prompt E embeds the requirement block only. Neither block is edited at run time, and neither is reproduced here in full, since duplicating one would create a second master that could drift from its source.

B.2.1 Scenario block

The scenario block is Sections 2 to 5 of the Scenario Brief at Appendix A, and it is used with Master Prompts A and B. Its profile table is relaid as labelled lines so that it survives being pasted into a chat interface, and the bracketed reference markers are dropped, the block travelling without a reference list. No wording is otherwise altered. Section 6, which names the requirement areas in scope, is deliberately left out: the requirement block supplies that material, and telling the model which requirements apply would hand it part of what the study sets out to measure.

ORGANISATION CONTEXT — NorthPay Ltd (fictitious UK e-commerce merchant)

[INSERT SB-01R, Sections 2 to 5, in full: the organisation profile, the technical

environment, the administrative environment, and the legislative and regulatory environment. Relay the profile table as labelled lines and drop the bracketed reference markers. Do not carry Section 6. Do not summarise or paraphrase; SB-01R is the versioned source, and citing a version is what makes the run reproducible.]

B.2.2 Requirement block

The requirement text is not retyped, summarised or pasted from the standard at run time. It comes from Appendix C, which holds the extract exactly as taken from PCI DSS v4.0.1. Below is the orientation list that heads the requirement text, followed by the insertion point. The extract itself goes in at the moment of the run, and the filename used is recorded against every output.

REQUIREMENTS TO ADDRESS (PCI DSS v4.0.1):

- Requirement 7 — Restrict access to system components and cardholder data by business need to know.
- Requirement 8 — Identify users and authenticate access to system components (including multi-factor authentication).
- Requirement 10 — Log and monitor all access to system components and cardholder data.
- Requirement 12 — Support information security with organisational policies and programmes (governance, risk, awareness training, third- party oversight [12.8], incident response [12.10]).

[INSERT REQ-01, Sections C.2 to C.5, in full. The four lines above are orientation only and are not a substitute for the requirement text. Do not paste from the standard directly; REQ-01 is the versioned source, and citing a version is what makes the run reproducible.]

B.3 Master Prompt A, standard-reference

Used to produce P1a (ChatGPT) and P2a (Grok).

You are producing a formal Information Security Policy for the organisation described below. Base the policy strictly on the PCI DSS v4.0.1 requirements provided. Cite the specific requirement numbers you address. Do not introduce requirements that are not listed, and do not include commentary outside the policy itself.

<<INSERT SCENARIO BLOCK>>

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

OUTPUT:

A single Information Security Policy covering the four requirement areas above. Use clear headings and numbered clauses. Against each section, reference the PCI DSS requirement number(s) it satisfies. Write nothing before or after the policy document.

B.4 Master Prompt B, compliance-framing

Used to produce P1b (ChatGPT) and P2b (Grok).

You are drafting a formal Information Security Policy for the organisation described below, intended to help it meet the PCI DSS v4.0.1 requirements provided. Write the policy so that it is compliant, enforceable and genuinely usable by a small firm. For each control area, make the underlying compliance intent explicit, and keep the language plain enough for non-specialist staff to follow. Where customer personal data is involved, note any point at which UK GDPR obligations intersect with PCI DSS. Keep every control proportionate to an organisation of roughly sixty people.

<<INSERT SCENARIO BLOCK>>

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

OUTPUT:

A single Information Security Policy covering the four requirement areas above, with:

1. clear headings and numbered clauses;
2. a reference to the relevant PCI DSS requirement number(s) against each section;
3. defined roles and responsibilities, and a stated review cadence;
4. plain-language notes on the compliance intent behind each major control.

Write nothing before or after the policy document.

B.5 Master Prompt C, cross-audit

Used at Phase 2, where Grok audits ChatGPT's policy and ChatGPT audits Grok's, so that no model assesses its own work. The rubric referred to below is the one at Appendix D, supplied to the auditing model in full and in both its layers rather than described to it.

You are auditing an Information Security Policy written for the organisation described below against the PCI DSS v4.0.1 requirements provided. You did not write this policy.

<<INSERT SCENARIO BLOCK>>

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

<<INSERT RUBRIC (Appendix D, RUB-01) IN FULL: the coverage checklist and its four rating levels, the definition of an accuracy defect, the four weighted criteria, the five band descriptors and the aggregation rule>>

<<INSERT THE POLICY UNDER AUDIT>>

OUTPUT, in four numbered parts:

1. Mapping. For each provision of the policy, state the requirement or sub-requirement it addresses.

2. Findings. List controls that are missing, weakly expressed or unenforceable. For each, state the requirement affected and tag it Technical, Administrative or Legislative.
3. Scoring. Complete the coverage checklist for each requirement area, rating every applicable sub-requirement; count the accuracy defects; then award a score from 0 to 100 for each requirement area using the four weighted criteria. Show the checklist total and the four criterion scores behind each requirement-area score.
4. Remediation. Propose prioritised remedial actions, most serious first.

Write nothing before or after these four parts.

B.6 Master Prompt D, refinement

Used at Phase 3, which is a contingency rather than a planned step. Each model receives the audit written on its own policy and revises accordingly, producing P1b-R and P2b-R.

Below is your own Information Security Policy for the organisation described, followed by an independent audit of it. Revise the policy so that it addresses the audit findings and improves its coverage of the PCI DSS v4.0.1 requirements provided. Keep the structure and the numbered clauses. Do not remove material that the audit did not criticise.

<<INSERT SCENARIO BLOCK>>

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

<<INSERT THE ORIGINAL POLICY>>

<<INSERT THE AUDIT OF THAT POLICY>>

OUTPUT:

The revised Information Security Policy in full. Write nothing before or after it.

B.7 Master Prompt E, control without scenario

Used to produce P1c (ChatGPT) and P2c (Grok). Identical to Master Prompt A except that the scenario block is absent; the output instruction is unchanged.

You are producing a formal Information Security Policy. Base the policy strictly on the PCI DSS v4.0.1 requirements provided. Cite the specific requirement numbers you address. Do not introduce requirements that are not listed, and do not include commentary outside the policy itself.

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

OUTPUT:

A single Information Security Policy covering the four requirement areas above.

Use clear headings and numbered clauses. Against each section, reference the PCI DSS requirement number(s) it satisfies. Write nothing before or after the policy document.

Two further things are recorded about every control run: whether the model asked for organisational context before answering, and whether it invented an organisation for itself. Both are observations for Phase 5 rather than scored behaviours.

B.8 Calibration prompt

Used at Phase 2, once per auditing model, before any live audit is issued. The model scores the two worked example extracts held at Appendix D, Sections D.8 and D.9, with the reference scorings withheld. Agreement with the reference scores of 47 and 73 is recorded in the scoring workbook at Appendix I before the first audit runs. Divergence found here is treated as a fault in the instrument rather than in the rater.

You are calibrating against a scoring rubric before auditing any policy. Two extracts from example Information Security Policies follow the rubric; both address PCI DSS v4.0.1 Requirement 8 only, for the organisation described below. Score each extract for Requirement 8 using the rubric: complete the coverage checklist, count the accuracy defects, then award the four criterion scores and the requirement-area score, showing the checklist total and the working behind each criterion score. Write nothing before or after the two scorings.

<<INSERT SCENARIO BLOCK>>

<<INSERT REQUIREMENT BLOCK (REQ-01, Sections C.2 to C.5)>>

<<INSERT RUBRIC (Appendix D, RUB-01, Sections D.1 to D.7) AS PLAIN TEXT, tables relaid as labelled lines>>

<<INSERT THE TWO WORKED EXAMPLE EXTRACTS (RUB-01, Sections D.8 and D.9, policy text only; the reference scorings are never included)>>

OUTPUT:

The completed checklist, the accuracy defect count, the four criterion scores and the requirement-area score, for Extract 1 and then Extract 2. Write nothing else.

B.9 One assembled prompt, as issued

Reproduced below is the file that was pasted into ChatGPT and into Grok to produce P1a and P2a, exactly as it was assembled and exactly as it was sent. It is Master Prompt A from Section B.3, with the scenario block and the requirement block substituted in full, which is what Section B.1 describes in the abstract. One condition is shown rather than all five. The remaining assembled files differ from

this one only in the master prompt at the head and, for the audit condition, in the rubric and policy text that follow, so reproducing all of them would repeat Appendices A, C and D at length. The assembled files for every condition are named against their runs in Appendix E and Appendix F.

Assembled 16 August 2026 from Prompt Library Master Prompt A, Scenario Brief Sections 2 to 5 and Requirement Text Extract Sections C.2 to C.5. Line breaks and spacing are those of the file as sent; nothing has been reflowed.

You are producing a formal Information Security Policy for the organisation described below. Base the policy strictly on the PCI DSS v4.0.1 requirements provided. Cite the specific requirement numbers you address. Do not introduce requirements that are not listed, and do not include commentary outside the policy itself.

ORGANISATION CONTEXT — NorthPay Ltd (fictitious UK e-commerce merchant)

PROFILE

- Name (fictitious): NorthPay Ltd.
- Sector: Online consumer retail, United Kingdom. A merchant within the payment card industry, and an online retailer rather than a regulated financial institution.
- Trading history: Incorporated in 2022; four of trading; privately held; registered office in Leeds.
- Business model: Primary business is sells its own homeware and small electrical goods directly to consumers through their website; currently there is no marketplace sellers, no business-to-business channel and no telephone ordering.
- Payment acceptance: At the time of sales, the card details are entered into fields supplied by a third-party payment service provider (PSP). The payment form is embedded in a checkout page that NorthPay itself serves. Script on that page initialises the PSP's fields and directs the customer's account data to the PSP. Once the payment has been authorised PSP returns an authorisation result and a token. A full primary account number (PAN) never reaches a NorthPay system.
- Annual volume: Approximately 340,000 card-not-present transactions in the last full trading year.
- Validation route: Merchant Level 3, assigned by the acquirer; validated through Self-Assessment Questionnaire A-EP with quarterly scans by an Approved Scanning Vendor (ASV).
- Assessment history: An Attestation of Compliance was signed at each of the last two annual validations. This is the second cycle assessed against PCI DSS v4.0.1.
- Cardholder data environment (CDE): NorthPay does not store customer credit card numbers, also known as Primary Account Numbers (PAN), on its own systems. However, the online storefront, checkout page, order management system, and administrator access paths are included in the security review (or deemed in scope of PCI assessment) because they connect to or impact the secure Cardholder Data Environment (CDE). NorthPay should follow security requirements stated in the PCI-DSS standard for these systems to prevent data from being intercepted or compromised.
- Headcount: 61 staff on the payroll.
- Security function: Two people: an Information Security Manager reporting to the Chief Technology Officer, and a compliance analyst working three days a week. No in-house Qualified Security Assessor (QSA).

TECHNICAL ENVIRONMENT

Hosting and network: All production workload runs in Amazon Web Services, in the London region and spread across three availability zones. NorthPay does not have its own data centre and no on-premises server estate except the office, which consists of networking, printers and a network-attached storage device used by the marketing team.

The storefront/website is built using Node.js, an application behind a content delivery network and a web application firewall. Order management, stock control and returns run on a commercial software-as-a-service platform reached over the public internet. Encrypted database snapshots and log archives replicate nightly to the Dublin region for recovery.

Production and non-production accounts are separated within a single cloud organisation. Admin access to AWS production environment is over a separate internal administration network (separate vLAN) rather than directly from the general office network.

The production estate is segmented using a single virtual private cloud (VPC) with public and private subnets in each availability zone. The application tier and the database sit in private subnets, and only the load balancer sits in a public subnet. Traffic filtering between each tiers via stateful security groups on each instance.

The settlement file is collected by a scheduled job over SFTP, authenticated with an SSH key pair held on a finance workstation. A second scheduled job retrieves stock availability files from a logistics partner over FTP in passive mode, inside the partner's own tunnel.

Cloud hosts synchronise to the platform time service. The software-as-a-service platforms keep their own clocks, and their exports are timestamped in UTC by the order management platform and in local time by the helpdesk platform.

Identity and access: A single cloud identity provider federates single sign-on to the cloud console, the order management platform, the PSP merchant portal, the helpdesk platform and the collaboration suite. The same provider provides multi-factor authentication (MFA) and conditional access on any of those applications.

Access is granted through groups rather than to individuals, and fourteen groups are in use; three of them were created for a project which finished in 2025 and still carry members.

At present multi-factor authentication is enforced on AWS cloud console and the collaboration suite.

Roughly 40 of the 61 staff hold an account in at least one system that is connected to, or impacts, the CDE: 18 in engineering, 14 in customer support, 6 in finance operations, and the 2 in security and compliance. Marketing, warehouse and logistics staff hold no such account.

The identity provider enforces a minimum password length of ten characters with complexity, an expiry of ninety days and lockout after six failed attempts. Administrative console sessions time out after sixty minutes of inactivity and sessions on the order management platform do not time out while the browser tab remains open.

No automatic account de-provisioning in place. Removal of access from the software-as-a-service platforms is done by hand on each platform.

Data flows and storage: Customer support staff resolve disputes through the PSP merchant portal. PSP only display first six and last four digits of the PAN alongside the authorisation code.

Finance team reconcile a daily settlement file from the PSP. The daily settlement file lists the transaction token, the last four digits and the settlement amount.

The order management platform stores the customer's name, delivery and billing address, contact details, order history and the last four digits of the card. Such data is considered as Personal Identifiable Information (PII) is in scope of GDPR. All the databases are encrypted with AES-256.

No full PAN, sensitive authentication data and no card verification value (also known as CVV code that can be found on the back of the payment card) is stored or transmitted anywhere in the estate.

Public traffic is secured using TLS 1.2 and TLS 1.3, using a certificate from a public certificate authority which renews automatically. All earlier protocol versions are disabled.

No inventory of cryptographic algorithms, protocol versions, certificates, key locations and key holders is maintained. Certificate expiry dates are tracked in a spreadsheet kept by one engineer.

Logging and monitoring: All AWS logs from Cloud audit trail events, network flow logs, load balancer logs and application logs are ingested in to a cloud-native security information and event management (SIEM) platform.

According to the current licence, the SIEM retains 90 days of searchable logs.

Older logs are deleted after 90 days or automatically overwritten as needed. As it stands, no offline or separate logs archive has been configured.

The order management platform produces its own administrator activity log, visible in that platform's interface and not forwarded to the SIEM. A set of random alerts is set up, and alerts arrive in a shared mailbox watched between 08:00 and 18:00 on working days. However, there is no twenty-four hour security operations centre.

Endpoints and change: Staff use company-issued laptops are with Windows 11 operating systems and are managed through a centralised device management tool. All the laptops are configured with full-disk encryption and automatic patching enabled.

Personal devices are also allowed and currently used for email and calendar but are not permitted to reach systems connected to the CDE. This restriction is currently enforced by convention rather than by conditional access policy.

All the software development codes are stored in a AWS based private code repository, a pull request requires one approving review, and a continuous deployment pipeline releases to production several times a week. Deployment credentials are held as repository secrets.

Quarterly ASV scans and one annual external penetration test are commissioned. The last penetration test was carried out in February 2026, and three medium-severity findings from it remain open.

ADMINISTRATIVE ENVIRONMENT

Governance: No information security steering group exists. Security matters reach the monthly senior leadership meeting when the Information Security Manager puts them on the agenda. In practice the Chief Technology Officer owns the PCI DSS programme, although this has not been written down anywhere.

Policy/ISMS estate: A set of template policies was purchased three years ago and lightly edited. Several name job titles that no longer exist. The last recorded review was in February 2025, and no approval signature, owner or review cycle is recorded on any of them.

Roles and training. Job descriptions for engineering and customer support make no mention of security responsibilities.

There is no written matrix separating the controls the PSP operates from those NorthPay retains.

An annual all-staff security awareness module is delivered through the learning platform. The training completion rate is at 78% in the last year. Staff who handle disputes or hold administrative access receive no role-specific training.

Third party suppliers: Eleven suppliers touch the cloud environment in some way. Currently there is no single register of suppliers maintained, and no due diligence is carried out at the time the contract is signed or annually.

Incident handling. Currently no IT incident procedure or related activities. No security-specific incident response plan has been written, hence no roles have been assigned for a suspected compromise of card data, and the notification path to the acquirer has never been tested.

Risk and evidence. NorthPay has produced no documented risk analysis of the kind v4.x expects where the frequency of a control is left to the entity to determine. Evidence for the last validation was assembled in the fortnight before the deadline, largely from screenshots and email threads.

LEGISLATIVE AND REGULATORY ENVIRONMENT

NorthPay is a controller of customer personal data under the UK GDPR and the Data Protection Act 2018, and is registered with the Information Commissioner's Office.

It relies on performance of a contract for order fulfilment, on legitimate interests for fraud prevention, and on consent for marketing.

No Data Protection Officer has been appointed and the responsibility sits informally with the Head of Finance and Legal, who holds no data protection qualification.

The personal data held comprises name, delivery and billing address, email address, telephone number, order history, the last four digits of the card, IP address and support correspondence. No special category data is processed. Order records are kept for seven years to meet tax record-keeping requirements. No retention period has been set for support tickets, marketing lists or log data, each of which contains personal data.

Head of Finance and Legal acknowledged that, under the UK GDPR, a controller must notify the Information Commissioner within seventy-two hours of becoming aware of a personal data breach where the statutory criteria are met. However, NorthPay holds no internal procedure that would meet that clock, and the relationship between that duty and the notification it owes its acquirer following a suspected card compromise has never been mapped.

Nightly replication of encrypted backups to the Dublin region constitutes a transfer outside the United Kingdom; the transfer is covered by the UK's adequacy regulations for the European Economic Area, but no record of it has been documented.

Email marketing falls under the Privacy and Electronic Communications Regulations 2003 as well as the UK GDPR. Returns and refunds, which is the route by which most disputes reach customer support, are governed by the Consumer Rights Act 2015 and the Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013.

One boundary should be stated without ambiguity. NorthPay does not lend, does not offer credit at the checkout, does not hold client money and holds no permission of any kind from the Financial Conduct Authority. No clause of the policy should assert an FCA obligation.

REQUIREMENTS TO ADDRESS (PCI DSS v4.0.1):

- Requirement 7 — Restrict access to system components and cardholder data by business need to know.
- Requirement 8 — Identify users and authenticate access to system components (including multi-factor authentication).
- Requirement 10 — Log and monitor all access to system components and cardholder data.
- Requirement 12 — Support information security with organisational policies and programmes (governance, risk, awareness training, third-party oversight [12.8], incident response [12.10]).

REQUIREMENT 7: RESTRICT ACCESS TO SYSTEM COMPONENTS AND CARDHOLDER DATA BY BUSINESS NEED TO KNOW

Sections:

7.1 Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.

7.2 Access to system components and data is appropriately defined and assigned.

Defined Approach Requirements:

7.1.1 All security policies and operational procedures that are identified in Requirement 7 are:

- Documented.
- Kept up to date.
- In use.
- Known to all affected parties.

7.1.2 Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood.

7.2.1 An access control model is defined and includes granting access as follows:

- Appropriate access depending on the entity's business and access needs.
- Access to system components and data resources that is based on users' job classification and functions.
- The least privileges required (for example, user, administrator) to perform a job function.

7.2.2 Access is assigned to users, including privileged users, based on:

- Job classification and function.
- Least privileges necessary to perform job responsibilities.

7.2.3 Required privileges are approved by authorized personnel.

7.2.4 All user accounts and related access privileges, including third-party/vendor accounts, are reviewed as follows:

- At least once every six months.
- To ensure user accounts and access remain appropriate based on job function.
- Any inappropriate access is addressed.
- Management acknowledges that access remains appropriate.

7.2.5 All application and system accounts and related access privileges are assigned and managed as follows:

- Based on the least privileges necessary for the operability of the system or application.
- Access is limited to the systems, applications, or processes that specifically require their use.

7.2.5.1 All access by application and system accounts and related access privileges are reviewed as follows:

- Periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1).
- The application/system access remains appropriate for the function being performed.
- Any inappropriate access is addressed.
- Management acknowledges that access remains appropriate.

7.2.6 All user access to query repositories of stored cardholder data is restricted as follows:

- Via applications or other programmatic methods, with access and allowed actions based on user roles and least privileges.
- Only the responsible administrator(s) can directly access or query repositories of stored CHD.

REQUIREMENT 8: IDENTIFY USERS AND AUTHENTICATE ACCESS TO SYSTEM COMPONENTS

Sections:

8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.

8.2 User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle.

8.3 Strong authentication for users and administrators is established and managed.

8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.

8.6 Use of application and system accounts and associated authentication factors is strictly managed.

Defined Approach Requirements:

8.1.1 All security policies and operational procedures that are identified in Requirement 8 are:

- Documented.
- Kept up to date.
- In use.
- Known to all affected parties.

8.1.2 Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.

8.2.1 All users are assigned a unique ID before access to system components or cardholder data is allowed.

8.2.2 Group, shared, or generic IDs, or other shared authentication credentials are only used when necessary on an exception basis, and are managed as follows:

- ID use is prevented unless needed for an exceptional circumstance.
- Use is limited to the time needed for the exceptional circumstance.
- Business justification for use is documented.
- Use is explicitly approved by management.
- Individual user identity is confirmed before access to an account is granted.
- Every action taken is attributable to an individual user.

8.2.4 Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are managed as follows:

- Authorized with the appropriate approval.
- Implemented with only the privileges specified on the documented approval.

8.2.5 Access for terminated users is immediately revoked.

8.2.6 Inactive user accounts are removed or disabled within 90 days of inactivity.

8.2.7 Accounts used by third parties to access, support, or maintain system components via remote access are managed as follows:

- Enabled only during the time period needed and disabled when not in use.
- Use is monitored for unexpected activity.

8.2.8 If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.

8.3.1 All user access to system components for users and administrators is authenticated via at least one of the following authentication factors:

- Something you know, such as a password or passphrase.
- Something you have, such as a token device or smart card.
- Something you are, such as a biometric element.

8.3.3 User identity is verified before modifying any authentication factor.

8.3.4 Invalid authentication attempts are limited by:

- Locking out the user ID after not more than 10 attempts.
- Setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.

8.3.5 If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they are set and reset for each user as follows:

- Set to a unique value for first-time use and upon reset.
- Forced to be changed immediately after the first use.

8.3.6 If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they meet the following minimum level of complexity:

- A minimum length of 12 characters (or IF the system does not support 12 characters, a minimum length of eight characters).
- Contain both numeric and alphabetic characters.

8.3.7 Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.

8.3.8 Authentication policies and procedures are documented and communicated to all users including:

- Guidance on selecting strong authentication factors.
- Guidance for how users should protect their authentication factors.
- Instructions not to reuse previously used passwords/passphrases.
- Instructions to change passwords/passphrases if there is any suspicion or knowledge that the password/passphrases have been compromised and how to report the incident.

8.3.9 If passwords/passphrases are used as the only authentication factor for user access (i.e., in any single-factor authentication implementation) then either:

- Passwords/passphrases are changed at least once every 90 days, OR
- The security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly.

8.3.11 Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used:

- Factors are assigned to an individual user and not shared among multiple users.
- Physical and/or logical controls ensure only the intended user can use that factor to gain access.

8.4.1 MFA is implemented for all non-console access into the CDE for personnel with administrative access.

8.4.2 MFA is implemented for all non-console access into the CDE.

8.4.3 MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.

8.6.1 If accounts used by systems or applications can be used for interactive login, they are managed as follows:

- Interactive use is prevented unless needed for an exceptional circumstance.
- Interactive use is limited to the time needed for the exceptional circumstance.
- Business justification for interactive use is documented.
- Interactive use is explicitly approved by management.
- Individual user identity is confirmed before access to account is granted.
- Every action taken is attributable to an individual user.

8.6.2 Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.

8.6.3 Passwords/passphrases for any application and system accounts are protected against misuse as follows:

- Passwords/passphrases are changed periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1) and upon suspicion or confirmation of compromise.
- Passwords/passphrases are constructed with sufficient complexity appropriate for how frequently the entity changes the passwords/passphrases.

REQUIREMENT 10: LOG AND MONITOR ALL ACCESS TO SYSTEM COMPONENTS AND CARDHOLDER DATA

Sections:

10.1 Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.

10.3 Audit logs are protected from destruction and unauthorized modifications.

10.4 Audit logs are reviewed to identify anomalies or suspicious activity.

10.5 Audit log history is retained and available for analysis.

10.7 Failures of critical security control systems are detected, reported, and responded to promptly.

Defined Approach Requirements:

10.1.1 All security policies and operational procedures that are identified in Requirement 10 are:

- Documented.
- Kept up to date.
- In use.
- Known to all affected parties.

10.1.2 Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.

10.3.1 Read access to audit logs files is limited to those with a job-related need.

10.4.1 The following audit logs are reviewed at least once daily:

- All security events.
- Logs of all system components that store, process, or transmit CHD and/or SAD.
- Logs of all critical system components.
- Logs of all servers and system components that perform security functions (for example, network security controls, intrusion-detection systems/intrusion-prevention systems (IDS/IPS), authentication servers).

10.4.2 Logs of all other system components (those not specified in Requirement 10.4.1) are reviewed periodically.

10.4.2.1 The frequency of periodic log reviews for all other system components (not defined in Requirement 10.4.1) is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.

10.4.3 Exceptions and anomalies identified during the review process are addressed.

10.5.1 Retain audit log history for at least 12 months, with at least the most recent three months immediately available for analysis.

10.7.3 Failures of any critical security control systems are responded to promptly, including but not limited to:

- Restoring security functions.
- Identifying and documenting the duration (date and time from start to end) of the security failure.
- Identifying and documenting the cause(s) of failure and documenting required remediation.
- Identifying and addressing any security issues that arose during the failure.
- Determining whether further actions are required as a result of the security failure.
- Implementing controls to prevent the cause of failure from reoccurring.
- Resuming monitoring of security controls.

REQUIREMENT 12: SUPPORT INFORMATION SECURITY WITH ORGANIZATIONAL POLICIES AND PROGRAMS

Sections:

12.1 A comprehensive information security policy that governs and provides direction for protection of the entity's information assets is known and current.

12.2 Acceptable use policies for end-user technologies are defined and implemented.

12.3 Risks to the cardholder data environment are formally identified, evaluated, and managed.

12.5 PCI DSS scope is documented and validated.

12.6 Security awareness education is an ongoing activity.

12.7 Personnel are screened to reduce risks from insider threats.

12.8 Risk to information assets associated with third-party service provider (TPSP) relationships is managed.

12.10 Suspected and confirmed security incidents that could impact the CDE are responded to immediately.

Defined Approach Requirements:

12.1.1 An overall information security policy is:

- Established.
- Published.

- Maintained.
 - Disseminated to all relevant personnel, as well as to relevant vendors and business partners.
- 12.1.2 The information security policy is:
- Reviewed at least once every 12 months.
 - Updated as needed to reflect changes to business objectives or risks to the environment.
- 12.1.3 The security policy clearly defines information security roles and responsibilities for all personnel, and all personnel are aware of and acknowledge their information security responsibilities.
- 12.1.4 Responsibility for information security is formally assigned to a Chief Information Security Officer or other information security knowledgeable member of executive management.
- 12.2.1 Acceptable use policies for end-user technologies are documented and implemented, including:
- Explicit approval by authorized parties.
 - Acceptable uses of the technology.
 - List of products approved by the company for employee use, including hardware and software.
- 12.3.1 For each PCI DSS requirement that specifies completion of a targeted risk analysis, the analysis is documented and includes:
- Identification of the assets being protected.
 - Identification of the threat(s) that the requirement is protecting against.
 - Identification of factors that contribute to the likelihood and/or impact of a threat being realized.
 - Resulting analysis that determines, and includes justification for, how the frequency or processes defined by the entity to meet the requirement minimize the likelihood and/or impact of the threat being realized.
 - Review of each targeted risk analysis at least once every 12 months to determine whether the results are still valid or if an updated risk analysis is needed.
 - Performance of updated risk analyses when needed, as determined by the annual review.
- 12.3.2 A targeted risk analysis is performed for each PCI DSS requirement that the entity meets with the customized approach, to include:
- Documented evidence detailing each element specified in Appendix D: Customized Approach (including, at a minimum, a controls matrix and risk analysis).
 - Approval of documented evidence by senior management.
 - Performance of the targeted analysis of risk at least once every 12 months.
- 12.3.3 Cryptographic cipher suites and protocols in use are documented and reviewed at least once every 12 months, including at least the following:
- An up-to-date inventory of all cryptographic cipher suites and protocols in use, including purpose and where used.
 - Active monitoring of industry trends regarding continued viability of all cryptographic cipher suites and protocols in use.
 - Documentation of a plan, to respond to anticipated changes in cryptographic vulnerabilities.
- 12.3.4 Hardware and software technologies in use are reviewed at least once every 12 months, including at least the following:
- Analysis that the technologies continue to receive security fixes from vendors promptly.
 - Analysis that the technologies continue to support (and do not preclude) the entity's PCI DSS compliance.
 - Documentation of any industry announcements or trends related to a technology, such as when a vendor has announced "end of life" plans for a technology.
 - Documentation of a plan, approved by senior management, to remediate outdated technologies, including those for which vendors have announced "end of life" plans.

12.5.1 An inventory of system components that are in scope for PCI DSS, including a description of function/use, is maintained and kept current.

12.5.2 PCI DSS scope is documented and confirmed by the entity at least once every 12 months and upon significant change to the in-scope environment. At a minimum, the scoping validation includes:

- Identifying all data flows for the various payment stages (for example, authorization, capture settlement, chargebacks, and refunds) and acceptance channels (for example, card- present, card-not-present, and e-commerce).
- Updating all data-flow diagrams per Requirement 1.2.4.
- Identifying all locations where account data is stored, processed, and transmitted, including but not limited to: 1) any locations outside of the currently defined CDE, 2) applications that process CHD, 3) transmissions between systems and networks, and 4) file backups.
- Identifying all system components in the CDE, connected to the CDE, or that could impact security of the CDE.
- Identifying all segmentation controls in use and the environment(s) from which the CDE is segmented, including justification for environments being out of scope.
- Identifying all connections from third-party entities with access to the CDE.
- Confirming that all identified data flows, account data, system components, segmentation controls, and connections from third parties with access to the CDE are included in scope.

12.6.1 A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures, and their role in protecting the cardholder data.

12.6.2 The security awareness program is:

- Reviewed at least once every 12 months, and
- Updated as needed to address any new threats and vulnerabilities that may impact the security of the entity's cardholder data and/or sensitive authentication data, or the information provided to personnel about their role in protecting cardholder data.

12.6.3 Personnel receive security awareness training as follows:

- Upon hire and at least once every 12 months.
- Multiple methods of communication are used.
- Personnel acknowledge at least once every 12 months that they have read and understood the information security policy and procedures.

12.6.3.1 Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including but not limited to:

- Phishing and related attacks.
- Social engineering.

12.6.3.2 Security awareness training includes awareness about the acceptable use of end-user technologies in accordance with Requirement 12.2.1.

12.7.1 Potential personnel who will have access to the CDE are screened, within the constraints of local laws, prior to hire to minimize the risk of attacks from internal sources.

12.8.1 A list of all third-party service providers (TPSPs) with which account data is shared or that could affect the security of account data is maintained, including a description for each of the services provided.

12.8.2 Written agreements with TPSPs are maintained as follows:

- Written agreements are maintained with all TPSPs with which account data is shared or that could affect the security of the CDE.
- Written agreements include acknowledgments from TPSPs that TPSPs are responsible for the security of account data the TPSPs possess or otherwise store, process, or transmit on behalf of the

entity, or to the extent that the TPSP could impact the security of the entity's cardholder data and/or sensitive authentication data.

12.8.3 An established process is implemented for engaging TPSPs, including proper due diligence prior to engagement.

12.8.4 A program is implemented to monitor TPSPs' PCI DSS compliance status at least once every 12 months.

12.8.5 Information is maintained about which PCI DSS requirements are managed by each TPSP, which are managed by the entity, and any that are shared between the TPSP and the entity.

12.10.1 An incident response plan exists and is ready to be activated in the event of a suspected or confirmed security incident. The plan includes, but is not limited to:

- Roles, responsibilities, and communication and contact strategies in the event of a suspected or confirmed security incident, including notification of payment brands and acquirers, at a minimum.
- Incident response procedures with specific containment and mitigation activities for different types of incidents.
- Business recovery and continuity procedures.
- Data backup processes.
- Analysis of legal requirements for reporting compromises.
- Coverage and responses of all critical system components.
- Reference or inclusion of incident response procedures from the payment brands.

12.10.2 At least once every 12 months, the security incident response plan is:

- Reviewed and the content is updated as needed.
- Tested, including all elements listed in Requirement 12.10.1.

12.10.3 Specific personnel are designated to be available on a 24/7 basis to respond to suspected or confirmed security incidents.

12.10.4 Personnel responsible for responding to suspected and confirmed security incidents are appropriately and periodically trained on their incident response responsibilities.

12.10.4.1 The frequency of periodic training for incident response personnel is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.

12.10.5 The security incident response plan includes monitoring and responding to alerts from security monitoring systems, including but not limited to:

- Intrusion-detection and intrusion-prevention systems.
- Network security controls.
- Change-detection mechanisms for critical files.
- The change-and tamper-detection mechanism for payment pages. This bullet is a best practice until its effective date; refer to Applicability Notes below for details.
- Detection of unauthorized wireless access points.

12.10.6 The security incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.

12.10.7 Incident response procedures are in place, to be initiated upon the detection of stored PAN anywhere it is not expected, and include:

- Determining what to do if PAN is discovered outside the CDE, including its retrieval, secure deletion, and/or migration into the currently defined CDE, as applicable.
- Identifying whether sensitive authentication data is stored with PAN.
- Determining where the account data came from and how it ended up where it was not expected.
- Remediating data leaks or process gaps that resulted in the account data being where it was not expected.

OUTPUT:

A single Information Security Policy covering the four requirement areas above. Use clear headings and numbered clauses. Against each section, reference the PCI DSS requirement number(s) it satisfies. Write nothing before or after the policy document.